

## **Junior GRC projekt – Kiberbiztonsági kockázat- és megfelelés alapok**

A projekt célja, hogy gyakoroljam a kiberbiztonsági Governance, Risk és Compliance (GRC) terület alapjait, és az eddigi tanulmányaim során megszerzett ismereteket egy fiktív szervezet példáján keresztül gyakorlatba ültessem.

### **1. A projekt fókusza**

- kockázat alapú gondolkodás megértése
- alapvető incidenskezelési folyamatok áttekintése,
- az üzletmenet-folytonosság és helyreállítás (BCP/DRP) szerepének megértése,
- valamint a hazai és európai uniós kiberbiztonsági szabályozások (KiberTV, NIS2, ISO/IEC 27001 és CIS Controls) alapelveinek megismerése.

A projekt egy fiktív szervezet példáján keresztül mutatja be a GRC szemléletet, tanulási és portfólió célból.

### **2. A szervezet bemutatása**

A projekt egy fiktív, közepes méretű, állami tulajdonú szervezet kiberbiztonsági működését mutatja be.

A szervezet főbb jellemzői:

- munkavállalók száma: körülbelül 200 fő,
- működés jellege: adminisztratív és szolgáltatási feladatok ellátása,
- IT környezet: helyben üzemeltetett (on-premise) rendszerek és felhőalapú szolgáltatások vegyes használata,
- kezelt adatok köre: személyes adatok, működési és adminisztratív dokumentumok.

A szervezet kiberbiztonsági célja az információk bizalmasságának, sértetlenségének és rendelkezésre állásának biztosítása (*CIA triád*).

### **3. Alap kockázatelemzés**

A kockázatelemzés célja, hogy azonosítsuk, hogy milyen kiberbiztonsági fenyegetések jelenthetnek kockázatot a szervezet működésére, valamint ezek milyen hatással lehetnek az információkra és a szolgáltatásokra.

A projekt egy egyszerű kockázatelemzési megközelítést alkalmaz, amely a kockázatokat valószínűség és hatás alapján értékeli.

#### **3.1 Vizsgált kockázatok**

A szervezet működését érintő főbb kiberbiztonsági kockázatok:

- Phishing támadások
- Jogosulatlan hozzáférés
- Ransomware fertőzés

- Adatvesztés vagy adatmegsemmisülés
- Belső felhasználói hibák vagy visszaélések (insider kockázat)

### **3.2 Kockázatok értékelése**

A kockázatok értékelése során minden kockázat esetében meghatározásra kerül:

- a kockázat bekövetkezésének valószínűsége,
- a kockázat lehetséges hatása,
- valamint az alapvető javasolt védelmi intézkedések.

#### **Phishing támadások:**

*Valószínűség: magas*

*Hatás: közepes-magas*

A phishing támadások célja a felhasználók megtévesztése és hitelesítő adatok megszerzése.

A sikeres támadás jogosulatlan hozzáféréshez vagy adatvesztéshez vezethet.

Javasolt intézkedések:

- felhasználók oktatása mire figyeljenek,
- többfaktoros hitelesítés alkalmazása (MFA),
- gyanús e-mailek jelentésének ösztönzése.

#### **Jogosulatlan hozzáférés:**

*Valószínűség: közepes*

*Hatás: magas*

Jogosulatlan hozzáférés esetén külső vagy belső szereplők érzékeny rendszerekhez vagy adatokhoz férhetnek hozzá.

Javasolt intézkedések:

- jogosultságkezelési szabályok alkalmazása,
- rendszeres hozzáférés-felülvizsgálat,
- erős jelszóházi rend.

#### **Ransomware:**

*Valószínűség: közepes*

*Hatás: magas*

Ransomware támadás esetén a rendszerek elérhetetlenné válhatnak, ami jelentős működési kiesést okozhat.

Javasolt intézkedések:

- rendszeres biztonsági mentések, offline is
- frissítések és javítások alkalmazása,
- végpontvédelem használata.

**Adatvesztés és adatmegsemmisülés:***Valószínűség: alacsony-közepes**Hatás: magas*

Adatvesztés történhet technikai hiba, emberi mulasztás vagy támadás következtében.

Javasolt intézkedések:

- mentési és visszaállítási eljárások,
- adatok megfelelő tárolása,
- hozzáférések korlátozása.

**Insider kockázat:***Valószínűség: alacsony-közepes**Hatás: közepes-magas*

Belső felhasználók szándékosan vagy véletlenül is okozhatnak biztonsági incidenseket.

Javasolt intézkedések:

- jogosultságok minimalizálása,
- naplózás és ellenőrzés,
- biztonságtudatosság növelése.

| Kockázat azonosító | Kockázat leírása        | Valószínűség     | Hatás         | Kockázati szint | Javasolt intézkedés                    |
|--------------------|-------------------------|------------------|---------------|-----------------|----------------------------------------|
| R-01               | Phishing támadások      | Magas            | Közepes-magas | Magas           | Felhasználói képzés, MFA               |
| R-02               | Jogosulatlan hozzáférés | Közepes          | Magas         | Magas           | Jogosultságkezelés, jelszóházi rend    |
| R-03               | Ransomware fertőzés     | Közepes          | Magas         | Magas           | Biztonsági mentések, végpontvédelem    |
| R-04               | Adatvesztés             | Alacsony-közepes | Magas         | Közepes         | Mentési és visszaállítási eljárások    |
| R-05               | Insider kockázat        | Alacsony-közepes | Közepes-magas | Közepes         | Jogosultságok minimalizálása, naplózás |

## **4. Incidenskezelési folyamat**

Az incidenskezelési folyamat célja, hogy a szervezet időben felismerje, kezelje és minimalizálja a kiberbiztonsági incidensek hatását.

A jól meghatározott incidenskezelési folyamat hozzájárul a működés folytonosságához, valamint a jogszabályi és szervezeti elvárások teljesítéséhez.

### **4.1 Az incidenskezelés lépései**

A szervezet az alábbi alaplépések szerint kezeli a kiberbiztonsági incidenseket:

1. Az incidens észlelése
2. Incidens jelentése az illetékes felelősnek
3. Információgyűjtés és elemzés
4. Reagálás
5. Helyreállítás
6. Utólagos értékelés és dokumentálás

### **4.2 Junior szerepkör az incidenskezelésben**

Junior szinten az incidenskezelésben betöltött szerep elsősorban támogató jellegű:

- incidensek dokumentálása,
- információgyűjtés támogatása,
- incidensnaplók vezetése,
- belső eljárások betartása,
- senior szakemberek munkájának segítése.

## **5. Üzletmenet-folytonosság (BCP) és helyreállítás (DRP)**

### **5.1 Üzletmenet-folytonosság (BCP) – alapelvek**

Az üzletmenet-folytonosság célja annak biztosítása, hogy egy kiberbiztonsági incidens vagy technikai meghibásodás esetén a szervezet kritikus tevékenységei a lehető legrövidebb időn belül folytathatók legyenek.

A szervezet a BCP keretében azonosítja:

- a kritikus üzleti folyamatokat,
- a kritikus informatikai rendszereket,
- a lehetséges kiesések üzleti hatását.

### **5.2 Helyreállítás (DRP) – alapelvek**

A katasztrófa utáni helyreállítási terv (*Disaster Recovery Plan – DRP*) célja az informatikai rendszerek és adatok helyreállítása egy súlyos incidens vagy kiesés után.

A helyreállítás során kiemelt szempont:

- az adatok visszaállítása biztonsági mentésekből,
- a rendszerek újraindítása,
- a szolgáltatások mielőbbi elérhetővé tétele.

### **5.3 Junior szerep a BCP/DRP folyamatban**

Junior szinten a BCP és DRP folyamatokban való részvétel elsősorban támogató és adminisztratív jellegű:

- a dokumentáció naprakészen tartása,
- helyreállítási folyamatok dokumentálása,
- tesztelések során megfigyelések rögzítése,
- senior munkatársak támogatása.

## **6. Jogszabályi és megfelelési szemlélet**

A projekt célja nem jogi elemzés készítése, hanem annak bemutatása, hogy a kiberbiztonsági megfelelés milyen szemléletet és alapelveket követ egy szervezet működésében.

### **6.1 Kiberbiztonsági szabályozások áttekintése**

A szervezet működését érintő főbb kiberbiztonsági szabályozások közé tartoznak a hazai és európai uniós előírások.

A projekt szempontjából érintett szabályozások:

- Kiberbiztonsági törvény (KiberTV),
- NIS2 irányelv.

### **6.2 Alapelvek a megfelelésben**

A kiberbiztonsági megfelelés során a szervezet az alábbi alapelveket követi:

- kockázatalapú védelem alkalmazása,
- incidenskezelési folyamatok kialakítása és működtetése,
- a működés dokumentálása,
- rendszeres felülvizsgálat és fejlesztés,
- üzletmenet-folytonosság biztosítása.

### **6.3 Junior szerep a megfelelési folyamatban**

Junior szinten a megfelelési folyamatban betöltött szerep elsősorban támogató és koordinációs jellegű:

- megfelelési dokumentumok karbantartása,
- belső eljárások nyomon követése,
- kockázatok és incidensek dokumentálása,
- auditokra való felkészülés támogatása.

## **6.4 Nemzetközi szabványok és keretrendszerek**

A jogszabályi megfelelés mellett a szervezet a kiberbiztonsági működés kialakításakor nemzetközi szabványokat és ajánlásokat is figyelembe vesz.

A projekt szempontjából releváns keretrendszerek:

- ISO/IEC 27001 információbiztonsági irányítási rendszer (ISMS),
- CIS Critical Security Controls (CIS Controls).

Az ISO/IEC 27001 szabvány keretet biztosít az információbiztonsági kockázatok azonosításához, kezeléséhez és dokumentálásához.

A CIS Controls gyakorlati, technikai és szervezeti védelmi intézkedéseket fogalmaz meg, amelyek támogatják a kockázatok csökkentését.

## **7. Projekt összefoglalása**

A Junior GRC projekt célja az volt, hogy junior szinten bemutassa a kiberbiztonsági Governance, Risk és Compliance (GRC) terület alapvető szemléletét és működését.

A projekt egy fiktív szervezet példáján keresztül mutatta be:

- a kiberbiztonsági kockázatok azonosítását és értékelését,
- az incidenskezelési folyamat alapjait,
- az üzletmenet-folytonosság és helyreállítás fontosságát,
- valamint a jogszabályi és szabványalapú megfelelési szemléletet.

## **8. Személyes reflexió**

A projekt elkészítése során lehetőségem volt gyakorlatban is alkalmazni a kiberbiztonsági Governance, Risk és Compliance (GRC) területhez kapcsolódó alapelveket.

A feladat során világossá vált számomra, hogy a GRC terület elsősorban nem technikai megoldásokról szól, hanem a kockázatok felismeréséről, priorizálásáról, valamint a megfelelő folyamatok és döntések kialakításáról.

A projekt tanulási és portfólió célból készült, korábbi tanulmányaim és ismereteim alapján. A projekt hozzájárult ahhoz, hogy magabiztosabban értem a GRC szemléletet, és megerősítette érdeklődésemet a kiberbiztonság kockázatkezelési és megfelelőségi területe iránt.

**Készítette: Szabó Zsófia Viola**